

SENTINAL SECURITY ASSESSMENT REPORT

Project: SENTINAL | Type: COMBINED | Date: 2026-09-03 03:59 UTC

Overall Risk Score	Critical	High	Medium	Low	Total Findings
99.1/100	32	54	29	11	126

1. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:**** CRITICAL POSTURE

The automated assessment of <https://ginandjuice.shop> identified immediate critical exposures requiring urgent remediation. A total of 126 findings were recorded, including 32 Critical and 54 High severity vulnerabilities.

****Key Risk Highlights:****

- Total Discovered Findings: 126 (Critical: 32, High: 54, Medium: 29, Low: 11)
- Correlated Exploit Chains: 1
- Primary Concern Areas: Cryptographic Failures, Insecure Deserialization, Container Security

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

2. Correlated Multi-Vector Attack Chains

[HIGH] Confirmed Cross-Site Scripting (XSS) Exploit Path (Confidence: VERY HIGH)

Scenario: An attacker can craft malicious links containing JavaScript payloads to hijack user sessions, steal session cookies, or perform actions on behalf of authenticated victims.
Remediation: 1. Context-encode all dynamic values before rendering in HTML templates. 2. Enforce a robust Content Security Policy (CSP) to restrict unauthorized script execution.

3. Findings Inventory

Sev	Source	Vulnerability	Location / Remediation
MEDIUM	SAST	Dockerfile Container Running as Root Containers running as root increase the impact of container escape vulnerabilities.	rutu4669-hue-vajra-c6d6652/Dockerfile <i>Fix:</i> Add `USER nonroot` or a dedicated unprivileged user before the ENTRYPOINT/CMD.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/aiohttp/client.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with `pickle` or `yaml.load(Loader=yaml.Loader)` allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/aiohttp/cookiejar.py <i>Fix:</i> Use `yaml.safe_load()` or JSON for data serialization instead of pickle.

MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/aiohttp/web_ws.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/anyio/to_process.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/apscheduler/jobstores/mongodb.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/apscheduler/jobstores/redis.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/apscheduler/jobstores/rethinkdb.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
HIGH	SAST	Potential SQL Injection via Unsanitized Query Execution Constructing SQL queries using string formatting, interpolation, or dynamic query variables without parameterized bindin	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/apscheduler/jobstores/sqlalchemy.py <i>Fix:</i> Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) o
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/apscheduler/jobstores/sqlalchemy.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/apscheduler/jobstores/zookeeper.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/cryptography/x509/extensions.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.

MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/dns/dnssec.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/dns/entropy.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/ecdsa/test_eddsa.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with <code>`pickle`</code> or <code>`yaml.load(Loader=yaml.Loader)`</code> allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/ecdsa/test_jacobi.py <i>Fix:</i> Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/ecdsa/test_keys.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/ecdsa/test_pyeccdsa.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/google/protobuf/proto_builder.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/httpx/_auth.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.

CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with `pickle` or `yaml.load(Loader=yaml.Loader)` allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/packaging/_structures.py <i>Fix:</i> Use `yaml.safe_load()` or JSON for data serialization instead of pickle.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/passlib/handlers/digests.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/passlib/tests/test_context.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/passlib/tests/test_utils_handlers.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/passlib/tests/test_utils_pbkdf2.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
HIGH	SAST	Potential SQL Injection via Unsanitized Query Execution Constructing SQL queries using string formatting, interpolation, or dynamic query variables without parameterized bindin	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/psycpg2/extras.py <i>Fix:</i> Use parameterized queries (e.g. `cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`) o
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with `pickle` or `yaml.load(Loader=yaml.Loader)` allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/pydantic/deprecated/parse.py <i>Fix:</i> Use `yaml.safe_load()` or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with `pickle` or `yaml.load(Loader=yaml.Loader)` allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/pydantic/v1/parse.py <i>Fix:</i> Use `yaml.safe_load()` or JSON for data serialization instead of pickle.
CRITICAL	SAST	Insecure Deserialization via Pickle / Unsafe YAML Deserializing untrusted data with `pickle` or `yaml.load(Loader=yaml.Loader)` allows arbitrary code execution via constr	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/pytz/__init__.py <i>Fix:</i> Use `yaml.safe_load()` or JSON for data serialization instead of pickle.

MEDIUM	SAST	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) MD5 and SHA-1 have known collision vulnerabilities and are unsuitable for password hashing or cryptographic signatures.	rutu4669-hue-vajra-c6d6652/backend/venv/lib/python3.11/site-packages/redis/commands/core.py <i>Fix:</i> Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage.
--------	------	---	--